

MedDefense Health Systems

Security Posture Assessment Report

Author: Security Analyst (successor to Marcus Webb) | **Date:** [assessment date] | **Period covered:** Jan–Jun 2026

■ **Navy bold** = report skeleton (fixed structure / section labels — reusable in any report) ■ **Maroon** = filled-in data (specific to this assessment)

1. Executive Summary

Diagnosis in one sentence: MedDefense's security posture today is prevention-only and effectively blind — the organization has reasonable controls stopping some attacks from starting, but almost no ability to notice one that succeeds, and almost no tested way to recover once it does.

Most critical finding: there is no functioning detection capability anywhere in the environment. Logs exist but nobody reviews them, and there is no alerting of any kind. A cryptocurrency-mining infection ran undetected on the billing server for at least two weeks — the same blind spot that, in three real-world hospital breaches reviewed for this report, allowed attackers to operate for hours to over three weeks before anyone noticed.

Top 3 recommended actions:

1. Deploy basic detection and monitoring (a modern SIEM tool), starting with the most critical systems — roughly \$30,000, within one month.
2. Move the only backup copy off the same network as the servers it protects, and add offsite cloud replication — roughly \$14,400/year, within one month.
3. Isolate the highest-risk medical devices (infusion pumps) onto their own protected network segment — roughly \$30,000, this quarter.

Budget implication: these and four other priority fixes fit within \$80,400 of the \$120,000 annual security budget, leaving reserve capacity for the next tier of improvements.

2. Scope and Methodology

What was assessed: all three MedDefense sites (Central Hospital, Westside Clinic, Corporate HQ), covering servers, endpoints, network infrastructure, medical IoT devices, applications, and the data they hold.

Sources used: the onboarding documentation package; six months of incident history; a physical walk-through of Central; configuration artifacts for the firewall, servers, and endpoints; a full internal network scan; three real-world healthcare breach reports used to validate findings; and a partially completed assessment left by the previous security analyst.

Limitations and assumptions: Corporate HQ's individual endpoints are covered by the network scan but were not itemized in the asset registry to the same depth as Central. Some findings (e.g., whether medical device management interfaces still use default credentials) are flagged as needing direct verification rather than confirmed fact. All financial figures are order-of-magnitude estimates, not vendor quotes, except where a specific quote is cited.

3. Asset Landscape

Inventory summary: 27 distinct assets documented across 7 categories: 13 servers, 4 medical IoT device groups (~200 individual devices), 3 applications, 2 network devices, 2 data stores, 2 endpoint groups (~450+ individual devices), and 1 physical infrastructure zone. Three of these 27 are confirmed Shadow IT systems operating with no official oversight.

Top 5 Critical Assets:

1. **ehr-db-01** — the database holding protected health information for 50,000+ patients.
2. **ad-dc-01** — the domain controller anchoring nearly every login in the organization.
3. **NAS-01** — the sole backup copy of every critical system, with no offsite copy.
4. **FortiGate 100F** — the single perimeter device for the entire Central site.
5. **BD Alaris infusion pump fleet** — devices directly controlling patient medication dosing, with a known, unmitigated vulnerability.

Data classification summary: of 8 major data categories identified, 5 are classified Restricted (patient records, medical imaging, real-time clinical data, system credentials, research data) and 3 Confidential (financial data, HR records, audit logs). The most significant protection weakness is at the Restricted level: system credentials, including a network switch password physically taped to a wall.

4. Current Security Controls

Control inventory: 16 documented controls — 10 Technical, 3 Administrative, 3 Physical. By function: 10 Preventive, 3 Detective, 1 Corrective, 2 Compensating (both still proposed, not yet implemented), 0 Deterrent.

Maturity assessment: MedDefense is moderately mature in prevention (firewall rules, password policy, antivirus, account lockout) and critically immature everywhere else. Detection exists on paper but not in practice. Only one corrective control exists (nightly backup), and it has never been tested at full scale. No control category has any deterrent function at all.

Key effectiveness findings: of the 16 controls, only 3 are rated fully "Strong." Antivirus excludes every server in the environment. The guard service covers one entrance, one shift, at one site. Camera coverage excludes the server room, network closet, and administrative wing entirely.

5. Gap Analysis

Methodology note: "no detective or corrective control" in the Critical/High rules below is read strictly — both functions absent, not just one. Where a corrective control (e.g., backup) exists but detective does not, the gap is rated High rather than Critical.

Gap	Level	Description	Affected Asset(s)	Potential Impact	Recommended Treatment
GAP-002	Critical	No functioning detection or incident response	Network-wide	Repeat of the 2-week undetected cryptominer	Mitigate: deploy SIEM + IR plan
GAP-003	Critical	Sole backup shares network/room with production	NAS-01	Simultaneous loss of production and recovery data	Mitigate: cloud backup replication
GAP-004	Critical	Infusion pumps have zero controls	BD Alaris fleet	Direct patient harm via dosage manipulation	Mitigate: dedicated VLAN
GAP-006	Critical	Network closet unlocked, credentials exposed	Network Core	Full network compromise, undetected	Mitigate: lock + credential rotation
GAP-010	Critical	Shared PACS login, no accountability	pacs-srv-01	Untraceable unauthorized imaging access	Mitigate: badge authentication
GAP-001	High	EHR database reachable network-wide, no detection	ehr-db-01	Patient record exfiltration with no alert generated	Mitigate: restrict port 5432 + logging

Distribution analysis: gaps concentrate overwhelmingly in Detective and Corrective functions, never in a total absence of Preventive measures — this confirms the pattern: MedDefense over-invests in prevention and has almost no ability to notice or recover when prevention fails.

6. Risk Treatment Recommendations

GAP-002 — No detection / incident response capability

Risk Level: Critical

Strategy: Mitigate

Justification: this is the single most systemic gap — it's the reason every prior incident (ransomware, cryptominer) went undetected for weeks. No other strategy addresses a root capability gap like this.

Proposed control(s): Deploy Wazuh (open-source SIEM) covering critical servers and the firewall first; draft a formal Incident Response Plan.

Estimated cost: \$10–50K

Implementation effort: Short-term (<1 month for Phase 1)

Expected risk reduction: High — converts "discovered by accident" into "discovered by design" across most other gaps.

Trade-offs: requires someone to actually monitor and respond to alerts once deployed — a tool without a process is just more unread logs.

GAP-003 — Backup repository (NAS-01) has no protection or redundancy

Risk Level: Critical

Strategy: Mitigate

Justification: a priced quote already exists (\$14,400/year for cloud replication), previously denied on budget grounds alone. This is the cheapest fix, per dollar of risk reduced, on the entire list.

Proposed control(s): Cloud backup replication with immutable storage (AWS S3 or Azure Blob).

Estimated cost: \$10–50K (annual recurring cost of ~\$14,400)

Implementation effort: Short-term (<1 month once approved)

Expected risk reduction: High — eliminates the single point of failure where production and backup can be destroyed together.

Trade-offs: recurring annual cost, not one-time; needs to survive future budget cycles.

Gap	Estimated Cost (this fiscal year)
GAP-002 (SIEM + IR plan)	~\$30,000
GAP-003 (cloud backup)	~\$14,400
GAP-004 (pump VLAN, Phase 1)	~\$30,000
GAP-006 (closet lock/camera)	~\$500
GAP-010 (PACS badge auth)	~\$5,000
GAP-001 (firewall rule)	~\$500
Total	~\$80,400

7. Conclusion and Next Steps

In business terms: MedDefense currently spends its security effort almost entirely on locking doors, with very little spent on noticing when a door has been forced or recovering afterward. Three real-world hospital breaches reviewed in this assessment were caused by this exact combination — not sophisticated attacks, but ordinary gaps like these left unaddressed.

If these recommendations are not implemented, the most likely outcome is not a hypothetical future risk, but a repeat of what has already happened twice on the organization's own billing server, at a scale that could affect clinical operations directly — as it already has once.

This assessment answers the internal question of what the organization has, and where the gaps are. It does not yet answer the external question the previous analyst had begun but never finished: who is actually targeting organizations like MedDefense, and how. The next phase of this program should be a formal External Threat Landscape Assessment, mapping the now-documented gaps against real attacker techniques (MITRE ATT&CK, CISA healthcare advisories).

Board Briefing — One-Page Executive Version

MedDefense's security today stops some attacks from starting, but has almost no way to notice one that succeeds, or to recover afterward.

Critical Finding: Our systems generate security logs, but no one reviews them, and nothing alerts us automatically. A cryptocurrency-mining infection ran undetected on our billing server for two weeks, discovered only because it slowed the computer down. If a more serious attacker got in the same way, we would likely find out only after patient care was already disrupted.

Priority Actions:

1. Install basic monitoring that alerts us to suspicious activity, starting with our most critical systems — about \$30,000, within one month.
2. Move our only data backup off the same network as the systems it protects, and store a copy offsite — about \$14,400 per year, within one month.
3. Separate our medication-dosing devices onto their own protected network so a breach elsewhere can't reach them — about \$30,000, this quarter.

Business Case: A similar hospital breach we reviewed cost \$3.2 million to recover from and eleven days of ambulance diversions — our entire \$120,000 budget is less than four percent of that one bad month.

Closing: Without action, the most likely outcome is not a hypothetical future risk, but a repeat of what has already happened twice on our own network.